Mise en place d'un Système de Management de la Sécurité de l'Information (SMSI) pour BioMarket

Analyse des risques, définition de la PSSI, élaboration du PCA et du plan d'actions de sécurité selon l'ISO/IEC 27001

Rédacteur : Quentin Berengolc

Date : 13/09/2026

Version : v1.0

SOMMAIRE

Introduction 3

Chapitre 1 – Analyse du contexte et des enjeux de cybersécurité de BioMarket 5

Chapitre 2 - Plan Projet pour la Certification du SMSI 12

Chapitre 3 - Élaboration de la Politique de Sécurité du Système d'Information (PSSI) 18

Chapitre 4 - Analyse des risques 22

Chapitre 5 – Élaboration du Plan de Continuité d'Activité (PCA) 25

Chapitre 6 – Élaboration du plan d'actions de sécurité 31

Conclusion générale 40

Liste des annexes 41

Introduction

Contexte

Dans un contexte de transformation numérique, les entreprises sont confrontées à une augmentation constante des cybermenaces. Les attaques visant les systèmes d'information, les plateformes de commerce électronique et les données personnelles se multiplient, rendant la cybersécurité indispensable pour garantir la continuité des activités et la confiance des clients.

BioMarket est une enseigne spécialisée dans la distribution de produits biologiques, implantée dans le Nord de la France et en Belgique. Afin de répondre aux nouvelles habitudes de consommation et de rester compétitive sur son marché, l'entreprise souhaite développer une plateforme de commerce électronique. Cette évolution constitue une opportunité de développement importante, mais implique également de nouveaux risques liés à la protection des données personnelles, à la disponibilité des services et à la sécurisation des échanges numériques.

Dans ce contexte, la Direction des Systèmes d'Information souhaite intégrer la cybersécurité dès la conception du projet afin de limiter les risques et de garantir la conformité avec les exigences réglementaires, notamment le Règlement Général sur la Protection des Données (RGPD), ainsi qu'avec les recommandations de l'ANSSI et les exigences de la norme ISO 27001.

Objectifs de la mission

La mission consiste à accompagner BioMarket dans la mise en place d'une démarche globale de cybersécurité adaptée à son projet de plateforme e-commerce.

Les principaux objectifs sont les suivants :

- analyser le contexte de l'entreprise et son système d'information ;
- identifier les actifs critiques, les besoins métiers et les parties prenantes ;
- mettre en place une veille technique, technologique et réglementaire ;
- évaluer l'exposition numérique de l'entreprise grâce à une analyse OSINT ;
- proposer une cartographie du système d'information ;
- préparer la mise en œuvre d'un Système de Management de la Sécurité de l'Information (SMSI) conforme à la norme ISO 27001 ;
- élaborer une Politique de Sécurité du Système d'Information (PSSI) ;
- définir un Plan de Continuité d'Activité (PCA) ;
- proposer un plan d'actions de sécurité priorisé accompagné d'une estimation budgétaire.

Méthodologie

La démarche adoptée s'appuie sur une analyse progressive du contexte de BioMarket. Les informations fournies sont complétées par une veille documentaire réalisée à partir de sources reconnues telles que l'ANSSI, le CERT-FR, la CNIL, le NIST, l'OWASP, MITRE ATT&CK, l'ENISA, ainsi que les référentiels ISO applicables.

La recherche d'informations repose sur la consultation de sources internes et externes fiables, leur recoupement, l'analyse de leur pertinence pour BioMarket et la traçabilité des informations retenues.

Les différentes recommandations sont justifiées au regard des risques identifiés, des besoins de l'entreprise et des exigences réglementaires applicables. Des tableaux d'analyse, des schémas d'architecture, des matrices de risques et des plans d'action sont utilisés afin de présenter les résultats de manière claire et structurée.

Organisation du rapport

Ce rapport est organisé en quatre grandes parties. La première présente BioMarket, son contexte, ses parties prenantes, les besoins de sécurité, la veille et la cartographie du système d'information. La deuxième est consacrée à la préparation du SMSI et à la rédaction de la PSSI. La troisième porte sur la continuité d'activité au travers de l'élaboration d'un PCA. Enfin, la dernière partie propose un plan d'actions de sécurité, une architecture cible, une estimation budgétaire ainsi qu'un planning de mise en œuvre.

L'objectif de ce travail est de proposer une démarche de cybersécurité cohérente, réaliste et conforme aux bonnes pratiques, afin d'accompagner BioMarket dans la sécurisation de son projet de transformation numérique.

Chapitre 1 – Analyse du contexte et des enjeux de cybersécurité de BioMarket

1.1 Présentation de BioMarket

BioMarket est une enseigne spécialisée dans la distribution de produits issus de l'agriculture biologique. Fondée il y a plus de vingt ans à Tourcoing, l'entreprise dispose de plus de cinquante points de vente répartis entre le Nord de la France et la Belgique. Son activité repose sur la commercialisation de produits biologiques, locaux et responsables.

Le développement de BioMarket repose notamment sur la qualité des produits, le respect de l'environnement, le bien-être des consommateurs et la transparence dans les relations avec les clients et partenaires. Ces valeurs impliquent des exigences de sécurité particulières, notamment en matière de protection des données personnelles, d'intégrité des informations commerciales et de disponibilité des services numériques.

Dans le cadre de sa stratégie de développement, BioMarket souhaite compléter son réseau de magasins par une plateforme de commerce électronique afin d'élargir sa clientèle, d'améliorer l'expérience utilisateur et de renforcer sa compétitivité. Développée par Iron4Software sur une infrastructure PaaS, cette plateforme constitue un nouveau composant du système d'information et du futur SMSI. Son exposition à Internet, le traitement de données personnelles et les échanges avec des prestataires renforcent les enjeux de cybersécurité du projet.

1.2 Analyse du contexte de l'entreprise

L'analyse du contexte interne montre que BioMarket est engagé dans une transformation numérique avec le développement d'une plateforme e-commerce. Cette évolution entraîne une augmentation des échanges numériques et du volume de données traitées, notamment les données clients, les commandes, les paiements, les fournisseurs et les salariés. BioMarket dispose déjà d'un socle de sécurité comprenant notamment un pare-feu Fortinet, un Active Directory, une authentification multifacteur pour certains comptes, un accès distant par VPN et une segmentation réseau par VLAN. Des axes d'amélioration subsistent toutefois en matière de gouvernance et de formalisation de la sécurité.

L'environnement externe est marqué par le développement du commerce électronique, l'évolution des attentes des consommateurs et l'augmentation des cybermenaces. BioMarket doit notamment prendre en compte la protection des données personnelles, les risques liés aux attaques contre les services en ligne et les exigences réglementaires et contractuelles applicables.

La synthèse PESTEL et SWOT met en évidence plusieurs facteurs déterminants : le développement du e-commerce constitue une opportunité de croissance, tandis que les rançongiciels, le vol de données, le phishing et l'indisponibilité de la plateforme représentent des menaces importantes. Les principales faiblesses identifiées concernent notamment la gestion des comptes après les départs, les pratiques relatives aux mots de passe, le stockage de certaines données sensibles en clair et une gouvernance SSI encore peu formalisée.

Les principaux enjeux métiers sont donc de garantir la disponibilité de la plateforme e-commerce, protéger les données personnelles, préserver la confiance des clients, assurer la fiabilité des commandes, stocks et paiements, et accompagner la croissance de l'entreprise sans compromettre la sécurité du système d'information.

Les analyses PESTEL et SWOT détaillées sont présentées en Annexe A.

1.3 Identification des parties prenantes

La sécurisation du système d'information de BioMarket implique des parties prenantes internes et externes dont les responsabilités, attentes et niveaux d'influence doivent être pris en compte dans la démarche de cybersécurité.

Les principales parties prenantes identifiées sont les suivantes :

Partie prenante	Rôle / attentes principales	Influence
Direction générale	Définit les orientations, valide les budgets et attend une maîtrise des risques	Très élevée
DSI	Pilote le SI et la sécurité ; attend une gouvernance et des mesures adaptées	Très élevée
RH	Gère les mouvements des collaborateurs et les habilitations	Élevée
Équipe informatique	Administre et maintient les infrastructures	Élevée
Collaborateurs	Utilisent quotidiennement le SI et doivent appliquer les règles de sécurité	Moyenne
DPO (à désigner)	Veille à la conformité en matière de données personnelles	Élevée
Clients	Utilisent la plateforme et attendent la protection de leurs données et la disponibilité du service	Élevée
Fournisseurs / partenaire logistique	Assurent les approvisionnements et échanges nécessaires à l'activité	Moyenne
Iron4Software	Développe la plateforme e-commerce et intervient sur les environnements associés	Élevée

L'analyse met en évidence trois acteurs particulièrement importants pour le projet : la Direction générale, la DSI et Iron4Software. Ils présentent un niveau d'influence élevé, en raison de leur capacité à orienter, piloter ou conditionner la mise en œuvre des mesures de sécurité, ainsi qu'un fort intérêt compte tenu de leur implication directe dans la gouvernance, l'exploitation ou la sécurité du système d'information.

Les attentes des principales parties prenantes portent ainsi sur la maîtrise des risques et la réussite du projet pour la Direction, la gouvernance et la sécurité du SI pour la DSI, la simplicité et la sécurité d'utilisation pour les collaborateurs, la protection des données et la disponibilité du service pour les clients, et la maîtrise des accès aux environnements de développement pour Iron4Software.

L'identification détaillée des parties prenantes et la matrice Pouvoir / Intérêt sont présentées en Annexe A.

1.4 Mise en place d'une veille cybersécurité.

1.4.1 Objectif et démarche

Dans le cadre de sa transformation numérique, BioMarket doit être en mesure d'identifier les nouvelles cybermenaces, vulnérabilités et évolutions réglementaires susceptibles d'affecter son système d'information.

Une veille cybersécurité est donc mise en place afin d'anticiper les risques, d'évaluer leur impact sur BioMarket et d'adapter les mesures de sécurité. Elle contribue également à l'amélioration continue du futur SMSI conformément aux principes de l'ISO/IEC 27001.

La démarche repose sur quatre étapes : **collecte des informations, analyse de leur pertinence et de leur criticité, évaluation de l'impact pour BioMarket, puis définition et suivi d'une action adaptée**. Les informations et actions associées sont tracées dans un tableau de suivi. Cette procédure détaillée est présentée en Annexe A.

1.4.2 Sources de veille

Les principales sources retenues sont :

Source	Domaine	Fréquence
ANSSI / CERT-FR	Alertes et menaces nationales	Quotidienne
CVE / CVSS	Vulnérabilités et criticité	Quotidienne
OWASP	Sécurité des applications Web	Hebdomadaire
MITRE ATT&CK	Techniques d'attaque	Hebdomadaire
CISA / ENISA	Menaces et recommandations internationales	Hebdomadaire / mensuelle
CNIL	Protection des données personnelles	Mensuelle
NIST	Référentiels et bonnes pratiques	Mensuelle

Ces sources couvrent les principaux besoins de BioMarket : vulnérabilités techniques, menaces, sécurité de la plateforme e-commerce, protection des données et évolutions des bonnes pratiques. La liste détaillée et les justifications sont disponibles en Annexe A.

1.4.3 Exemple d'alerte et traitement

Une alerte de sécurité publiée par le CERT-FR concernant une vulnérabilité affectant un équipement VPN est identifiée lors de la veille. La vulnérabilité est évaluée comme critique et susceptible d'avoir un impact important sur BioMarket, notamment en raison de l'exposition des accès distants. La DSI vérifie si l'équipement concerné est utilisé par BioMarket, évalue son exposition puis applique le correctif de sécurité lorsque celui-ci est disponible. Un contrôle est ensuite réalisé afin de vérifier que la vulnérabilité a bien été corrigée.

Cet exemple illustre le principe de traitement retenu : **identifier → évaluer → prioriser → corriger → vérifier**.

1.5 Analyse OSINT

1.5.1 Objectif

Une analyse OSINT (*Open Source Intelligence*) a été réalisée afin d'évaluer l'exposition numérique publique de BioMarket. Elle vise à identifier les informations accessibles publiquement pouvant être exploitées par un attaquant lors d'une phase de reconnaissance.

Cette analyse ne constitue pas une tentative d'intrusion. Elle consiste à identifier les informations et ressources exposées afin de réduire la surface d'attaque de BioMarket avant la mise en production de la plateforme e-commerce. La méthodologie et les outils utilisés sont détaillés en Annexe A.

1.5.2 Principaux résultats

L'analyse a mis en évidence plusieurs points de vigilance :

Constat	**Risque associé**	**Niveau**
Dépôts GitHub contenant des identifiants en clair	Compromission de comptes et accès non autorisés	**Critique**
Sous-domaines accessibles sans protection	Reconnaissance de l'infrastructure	**Élevé**
Fichiers CSV accessibles sans authentification	Divulgation de données sensibles	**Critique**
Certificats TLS révélant des sous-domaines internes	Facilitation de la cartographie du SI	**Moyen**

L'analyse a notamment identifié des sous-domaines tels que test.biomarket.fr et admin.biomarket.fr. Leur exposition peut révéler l'existence d'environnements techniques distincts et faciliter la reconnaissance du système d'information. Les environnements de test présentent notamment un risque lorsqu'ils bénéficient d'un niveau de protection inférieur à celui de la production.

1.5.3 Recommandations

Les principales mesures recommandées sont :

- supprimer les identifiants exposés;
- effectuer régulièrement une revue des dépôts de code ;
- supprimer ou sécuriser les sous-domaines inutilisés ou insuffisamment protégés ;
- protéger les fichiers sensibles par authentification et contrôle des autorisations ;
- réaliser périodiquement une analyse OSINT de l'exposition publique de BioMarket.

Ces mesures devront être intégrées aux actions de sécurité et prises en compte avant la mise en production de la plateforme e-commerce. Les recommandations détaillées sont présentées en Annexe A.

1.6 Identifier les besoins spécifiques de BioMarket en matière de sécurité

1.6.1 Objectif

Avant de définir les mesures de protection, BioMarket doit identifier ses principaux besoins en matière de sécurité de l'information. Cette analyse permet de déterminer les exigences de protection applicables aux actifs et activités critiques et constitue une étape préalable à l'analyse des risques.

Les besoins sont évalués selon le modèle **DICP : Disponibilité, Intégrité, Confidentialité et Preuve (Traçabilité)**.

1.6.2 Besoins de sécurité

Le développement de la plateforme e-commerce entraîne le traitement de données personnelles, de commandes, d'informations fournisseurs, de données financières et d'informations internes. La présence du prestataire **Iron4Software** introduit également des enjeux liés à la sécurité des développements et à la gestion des accès.

Les principaux besoins identifiés sont les suivants :

Besoin de sécurité	**Justification**	**Critère DICP**
Protéger les données personnelles des clients	Respect du RGPD et protection de la vie privée	Confidentialité
Garantir l'intégrité des commandes	Éviter les erreurs ou modifications frauduleuses	Intégrité
Assurer la disponibilité de la plateforme e-commerce	Garantir la continuité des ventes	Disponibilité
Sécuriser les accès des administrateurs et d'Iron4Software	Limiter les accès non autorisés	Confidentialité / Preuve
Journaliser les actions	Faciliter les audits et investigations	Preuve
Sauvegarder les données critiques	Permettre la restauration après incident	Disponibilité
Sécuriser les développements du prestataire	Prévenir l'introduction de vulnérabilités	Intégrité / Confidentialité
Sensibiliser les collaborateurs	Réduire les risques liés aux erreurs humaines	DICP

Ces besoins couvrent les principaux enjeux de sécurité identifiés pour BioMarket et serviront de base à l'analyse des risques et à la définition des mesures de traitement.

1.6.3 Mécanismes de sécurité associés

Les besoins identifiés sont couverts par plusieurs mécanismes complémentaires, selon une approche de défense en profondeur :

Besoin	Principaux mécanismes
Confidentialité	Contrôle d'accès, MFA, chiffrement
Intégrité	Contrôle des modifications, revues de code, EDR
Disponibilité	Sauvegardes, redondance, PCA
Preuve	Journalisation, supervision SIEM, conservation des logs
Réseau	Pare-feu, segmentation, VPN
Sensibilisation	Formations régulières

Ces mécanismes seront précisés et priorisés dans les chapitres consacrés à l'analyse des risques, à la PSSI et au plan d'actions de sécurité.

1.6.4 Exemple d’action préventive

Afin de réduire le risque de compromission des comptes, BioMarket peut prévoir de généraliser l’authentification multifacteur (MFA) pour les comptes à privilèges, les accès VPN, les services Cloud et les accès d’administration. Cette mesure préventive vise à limiter l’exploitation d’identifiants compromis.

1.7 Cartographie de l'architecture technique actuelle

1.7.1 Objectif et périmètre

La cartographie de l'architecture technique permet de représenter les principaux composants du système d'information de BioMarket, leurs interconnexions et les échanges avec les environnements externes.

Elle couvre notamment le site principal de Tourcoing, les magasins reliés par le réseau MPLS, les réseaux locaux et leurs VLAN, les serveurs d'infrastructure et métiers, les postes utilisateurs, les accès distants, le stockage Cloud et la plateforme e-commerce hébergée par Iron4Software sur une infrastructure PaaS.

La plateforme e-commerce est considérée comme un composant du SI de BioMarket, même si son infrastructure PaaS et ses composants internes sont administrés par le prestataire.

1.7.2 Synthèse de l'architecture

L'architecture actuelle est centralisée autour du site de Tourcoing. Le FortiGate 100F assure notamment le filtrage des communications, le routage inter-VLAN et les accès VPN. Le FortiSwitch 148F assure la commutation du réseau.

Les services d'infrastructure sont principalement regroupés dans le VLAN 50, notamment l'Active Directory, le DNS et le DHCP. Le VLAN 60 est dédié au management des équipements réseau. Les postes utilisateurs sont répartis sur plusieurs VLAN.

Les magasins sont raccordés au site principal par un réseau MPLS privé. Les utilisateurs nomades accèdent aux ressources internes au moyen d'un VPN SSL. La plateforme e-commerce est accessible

depuis Internet et échange avec le SI de BioMarket au moyen d'API sécurisées en HTTPS. Le stockage Cloud constitue également un environnement externe connecté au SI.

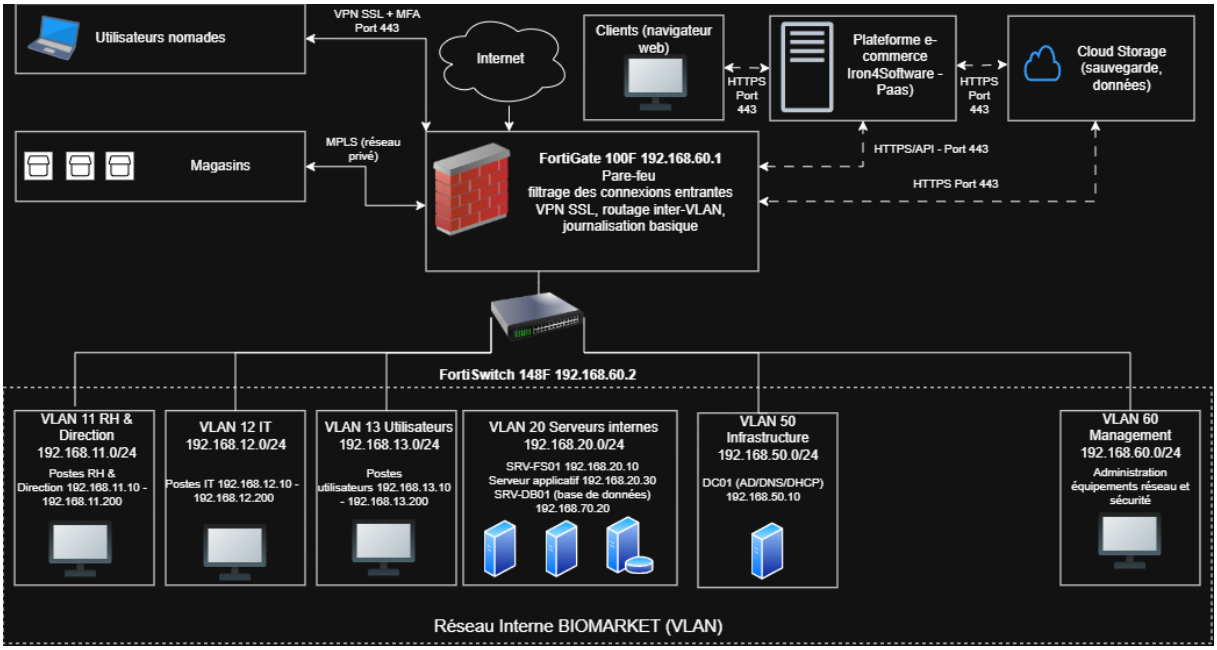


Figure 1 – Cartographie synthétique de l'architecture technique actuelle de BioMarket

1.7.3 Principaux points de vigilance

La cartographie met en évidence plusieurs éléments importants pour la sécurité :

- la centralisation de plusieurs services critiques sur le site de Tourcoing ;
- la dépendance à Iron4Software pour la plateforme e-commerce ;
- l'exposition Internet de la plateforme e-commerce et de ses interfaces d'échange avec le SI ;
- le stockage local de certaines données sans chiffrement au repos ;
- la nécessité de renforcer la traçabilité et la centralisation des journaux de sécurité.

Ces éléments sont pris en compte dans l'analyse des risques et dans la définition de l'architecture cible.

Chapitre 2 - Plan Projet pour la Certification du SMSI

2.1 Définition du périmètre à certifier

2.1.1 Périmètre de certification

L'objectif est de définir le périmètre du SMSI qui fera l'objet de la certification ISO/IEC 27001. Le périmètre couvre les activités, informations, actifs et processus nécessaires au fonctionnement du système d'information de BioMarket.

Le périmètre retenu comprend :

- le **site principal de Tourcoing** et les magasins reliés au siège par le réseau MPLS ;
- les **infrastructures réseau**, serveurs et postes de travail exploités par BioMarket ;
- les services d'infrastructure, notamment **Active Directory, DNS, DHCP, serveur de fichiers et base de données** ;
- les **données métier et données personnelles** traitées par BioMarket ;
- les accès distants réalisés via **VPN SSL** ;
- les stockages **locaux et Cloud** ;
- les échanges avec les prestataires ayant un impact sur la sécurité du SI, notamment **Iron4Software** ;
- la **plateforme e-commerce**, considérée comme un composant du système d'information de BioMarket.

La plateforme e-commerce est donc intégrée au périmètre du SMSI, bien que son infrastructure PaaS soit administrée par Iron4Software. Le périmètre porte sur les données, les interfaces, les échanges et les exigences de sécurité relevant de BioMarket. L'infrastructure interne et physique administrée par le prestataire reste hors du périmètre opérationnel de BioMarket.

2.1.2 Principaux processus couverts

Le périmètre couvre notamment les processus liés à :

Processus	Enjeu de sécurité
Gestion des identités et des accès	Maîtrise des droits et authentification
Gestion des données clients	Protection des données personnelles
Administration du SI	Disponibilité et sécurité des infrastructures
Gestion documentaire	Confidentialité et intégrité des informations
Accès distants	Sécurisation des connexions VPN
Gestion du projet e-commerce	Sécurité des échanges avec Iron4Software

Les actifs et processus détaillés sont présentés dans **l'Annexe B – Plan Projet pour la Certification du SMSI**.

2.1.3 Éléments hors périmètre opérationnel

Sont exclus du périmètre opérationnel de BioMarket :

- l’infrastructure PaaS et les composants techniques directement administrés par Iron4Software ;
- l'infrastructure physique du fournisseur Cloud ;
- les équipements personnels des clients ;
- les réseaux publics Internet.

Ces éléments ne sont pas directement administrés par BioMarket. Toutefois, les risques liés à ces dépendances sont pris en compte dans l'analyse des risques et les exigences de sécurité applicables aux prestataires.

2.2 Analyse des enjeux internes et externes

2.2.1 Enjeux internes et externes

La mise en place du SMSI doit répondre aux enjeux liés à la transformation numérique de BioMarket, à la protection de ses informations et à son environnement externe. L'analyse détaillée du contexte est présentée dans l'Annexe B – Plan Projet pour la Certification du SMSI.

Enjeux internes	**Enjeux externes**
Développer une plateforme e-commerce sécurisée	Maintenir la compétitivité sur le marché
Protéger les données clients, RH, financières et fournisseurs	Préserver la confiance des clients
Formaliser et harmoniser les pratiques de sécurité	Respecter les exigences réglementaires, notamment le RGPD
Renforcer la gouvernance et le pilotage de la sécurité	Maîtriser les risques liés aux prestataires
Garantir la disponibilité des services critiques	Faire face à l'évolution des cybermenaces

Le développement du e-commerce constitue à la fois un **enjeu de développement** et un **enjeu de sécurité**, en augmentant l'exposition de BioMarket aux menaces externes. La protection des données et la disponibilité des services sont également essentielles au maintien de la confiance des clients.

Sur le plan organisationnel, l'analyse montre la nécessité de mieux formaliser les processus de sécurité, la gestion des accès et le pilotage du SMSI. Sur le plan externe, les relations avec les prestataires, notamment **Iron4Software**, ainsi que les exigences réglementaires renforcent les besoins de maîtrise des risques.

Ces enjeux orientent la définition du périmètre du SMSI, l'analyse des risques, les exigences de sécurité et les actions d'amélioration retenues dans la suite du projet.

2.3 Définition des exigences juridiques et réglementaires

2.3 Exigences juridiques, réglementaires et normatives

BioMarket doit prendre en compte les exigences applicables à son activité, notamment en matière de protection des données personnelles, de sécurité du système d'information et de relations avec les prestataires. Ces exigences sont intégrées dans les politiques, procédures et mesures de sécurité du SMSI.

Référentiel / exigence	**Application chez BioMarket**	**Réponse attendue**
RGPD	Données clients, salariés et fournisseurs	Protection des données, maîtrise des accès, documentation des traitements et gestion des violations
ISO/IEC 27001	Projet de certification du SMSI	Mise en place d'un système de management documenté et amélioration continue
ISO/IEC 27002 / ANSSI	Bonnes pratiques de sécurité	Définition et renforcement des mesures de sécurité
Contrats prestataires	Iron4Software et fournisseur Cloud	Clauses de sécurité, confidentialité, accès et gestion des incidents

Exemple d'obligation réglementaire – RGPD

BioMarket traite des données à caractère personnel relatives notamment à ses clients et à ses salariés. À ce titre, l'entreprise doit mettre en œuvre des mesures techniques et organisationnelles appropriées afin de garantir un niveau de sécurité adapté aux risques liés aux traitements.

Un exemple concret concerne la notification des violations de données personnelles. En cas de violation de données susceptible d'engendrer un risque pour les droits et libertés des personnes concernées, BioMarket doit disposer d'un processus permettant d'identifier, d'évaluer et de traiter rapidement l'incident, notamment afin de déterminer si une notification à l'autorité de contrôle est nécessaire.

Cette exigence implique notamment de formaliser la gestion des incidents, de définir les responsabilités, d'assurer la traçabilité des événements et de permettre une remontée rapide des informations vers les personnes compétentes, notamment le DPO.

Pour BioMarket, cette obligation se traduit par la mise en place d'une procédure de gestion des incidents, d'une journalisation des événements de sécurité, d'un contrôle des accès et d'une organisation permettant d'évaluer rapidement l'impact d'une éventuelle fuite de données personnelles.

Prestataires

Les relations avec les prestataires constituent également un point de vigilance. Les contrats avec **Iron4Software** et le fournisseur Cloud doivent préciser les responsabilités de chaque partie, les exigences de confidentialité et de sécurité, ainsi que les modalités de gestion des incidents et d'accès aux données.

Les exigences détaillées et leur prise en compte dans la PSSI sont présentées dans les annexes correspondantes.

2.4 Gouvernance du projet

La gouvernance du projet de certification repose sur une implication de la **Direction Générale**, un pilotage opérationnel assuré par la **DSI** et une collaboration entre les équipes internes et les prestataires.

La gouvernance retenue s'appuie sur les principes suivants :

- validation des orientations et décisions stratégiques par la Direction Générale ;
- pilotage opérationnel du projet par la DSI ;
- participation des équipes informatiques et métiers ;
- prise en compte des exigences relatives aux données personnelles par le **DPO (à désigner)** ;
- implication d'Iron4Software pour les sujets liés à la plateforme e-commerce ;
- accompagnement méthodologique par le consultant cybersécurité.

Organisation et responsabilités

Acteur	Responsabilité principale
Direction Générale	Valide les orientations, le budget et les décisions majeures
DSI	Pilote le projet et coordonne les équipes
Équipe informatique	Met en œuvre les mesures techniques et les procédures
RH	Gère les mouvements des collaborateurs et les habilitations
DPO (à désigner)	Accompagne BioMarket sur les exigences RGPD
Responsables métiers / magasins	Expriment les besoins et appliquent les procédures
Consultant cybersécurité	Accompagne la mise en œuvre du SMSI et la préparation à la certification
Iron4Software	Intervient sur les sujets liés au développement et à la sécurité de la plateforme e-commerce

Comité de pilotage

Le **COPIL** assure le suivi du projet, la validation des livrables et les arbitrages nécessaires. Il réunit les principales parties prenantes du projet et se réunit **mensuellement ou lors des jalons majeurs**. La DSI assure le pilotage quotidien et prépare les éléments soumis au COPIL.

La répartition détaillée des responsabilités entre les différents acteurs est formalisée dans la **matrice RACI présentée en Annexe C1 – Matrice RACI de la sécurité**.

Communication et suivi

Le suivi repose sur des points réguliers entre la DSI, l'équipe informatique et les parties prenantes concernées, ainsi que sur les réunions du COPIL. Les décisions et actions sont tracées afin d'assurer leur suivi jusqu'à leur clôture.

Cette organisation permet de maintenir une responsabilité claire entre les décisions stratégiques, le pilotage opérationnel et la mise en œuvre des mesures de sécurité.

2.5 Calendrier, jalons et budget prévisionnel

2.5.1 Calendrier et jalons

Le projet de certification du SMSI est prévu sur une durée d'environ **9 mois**. Il suit une progression allant de la définition du périmètre et de l'analyse du contexte jusqu'au déploiement des mesures de sécurité et à la préparation de la certification.

Les principales phases sont les suivantes :

Phase	**Période**
Lancement et définition du périmètre	M1–M2
Analyse des enjeux et exigences réglementaires	M2–M3
Analyse des risques	M3–M6
Élaboration de la PSSI	M4–M6
Élaboration du PCA	M5–M7
Déploiement des actions de sécurité	M6–M9
Audit interne et préparation à la certification	M8–M9

Le planning détaillé et les jalons associés sont présentés dans **l'Annexe B – Plan Projet pour la Certification du SMSI**.

2.5.2 Budget prévisionnel

Le budget global prévisionnel du projet s'élève à **315 000 € HT**. Il comprend les ressources nécessaires à l'accompagnement du projet, à la préparation de la certification, à la documentation, à la formation ainsi qu'au renforcement des mesures de sécurité.

Poste	**Coût estimé HT**
Consultant cybersécurité	35 000 €
Formation des collaborateurs	10 000 €
Préparation audit ISO	15 000 €
Documentation SMSI	10 000 €
Outils de gestion du projet	10 000 €
Mise en œuvre et renforcement des mesures de sécurité	195 000 €

Poste	Coût estimé HT
Assistance Iron4Software	20 000 €
Réserve projet	20 000 €
Total	**315 000 €**

Ce budget constitue une estimation initiale destinée au pilotage du projet. Les montants définitifs pourront évoluer selon les choix techniques, les prestataires retenus et les besoins identifiés lors de la mise en œuvre.

Le détail du budget et sa répartition sont présentés dans l'**Annexe B – Plan Projet pour la Certification du SMSI**.

2.5.3 Suivi

Le suivi du projet repose principalement sur l'avancement des tâches, le respect des jalons, la consommation budgétaire, le suivi des risques et la réalisation des livrables. Ces éléments sont examinés dans le cadre du pilotage du projet et permettent d'identifier les éventuels écarts et de mettre en place les actions correctives nécessaires.

Chapitre 3 - Élaboration de la Politique de Sécurité du Système d'Information (PSSI)

3.1 Objectif de la PSSI

Dans le cadre de la mise en œuvre du Système de Management de la Sécurité de l'Information (SMSI), une **Politique de Sécurité du Système d'Information (PSSI)** a été élaborée afin de formaliser les engagements de BioMarket en matière de cybersécurité.

Ce document constitue le référentiel de gouvernance du SMSI. Il définit les principes généraux de sécurité, les responsabilités des différents acteurs, les objectifs à atteindre ainsi que les mesures prioritaires destinées à protéger les actifs informationnels de l'entreprise.

La PSSI répond aux besoins identifiés lors de l'analyse du contexte réalisée en première partie. Elle prend notamment en compte le développement de la plateforme e-commerce, la protection des données personnelles, les accès distants des collaborateurs ainsi que les exigences réglementaires applicables, en particulier le RGPD.

La présente PSSI constitue également la note de cadrage de la politique de sécurité de BioMarket. Elle précise le périmètre de la démarche, les engagements de la Direction, les objectifs du SMSI, les responsabilités des acteurs et les principales mesures de sécurité à mettre en œuvre.

*La version complète de cette politique est présentée en **Annexe C**.*

3.2 Périmètre de la politique

Le périmètre de la PSSI correspond au périmètre retenu pour le SMSI.

Il couvre :

- le siège social de Tourcoing ;
- les magasins connectés au système d'information ;
- les infrastructures réseau et les serveurs ;
- l'Active Directory centralisé ;
- les applications métiers ;
- la future plateforme e-commerce développée par Iron4Software ;
- les données clients, les données RH et les données commerciales ;
- les collaborateurs et les prestataires disposant d'un accès au système d'information.

La définition de ce périmètre permet de concentrer les efforts de sécurisation sur les processus et les actifs présentant le plus fort impact pour l'entreprise.

3.3 Engagement de la Direction

La Direction Générale soutient officiellement la mise en œuvre du SMSI et affirme son engagement en faveur de la sécurité de l'information.

Elle s'engage notamment à :

- fournir les ressources nécessaires au projet ;
- définir les objectifs de sécurité ;
- promouvoir une culture de cybersécurité ;
- assurer le respect des exigences réglementaires ;
- soutenir l'amélioration continue du SMSI.

Cet engagement constitue un prérequis indispensable à la réussite d'une démarche de certification ISO/IEC 27001. Cet engagement est formalisé dans la lettre d'engagement présentée en Annexe C8

3.4 Objectifs du SMSI

L'objectif stratégique de BioMarket est de mettre en place un niveau de sécurité adapté aux enjeux de l'entreprise afin de protéger les informations et les ressources critiques, d'assurer la continuité des activités et de renforcer la confiance des clients et des partenaires, tout en préparant l'organisation à une future certification conforme à l'ISO/IEC 27001.

Les objectifs du SMSI sont les suivants :

- protéger la confidentialité, l'intégrité et la disponibilité des informations ;
- réduire les risques liés aux comptes à privilèges, aux rançongiciels, aux prestataires et aux données personnelles ;
- renforcer la maîtrise des accès et des habilitations ;
- améliorer la détection, la gestion et la traçabilité des incidents de sécurité ;
- assurer la continuité des activités critiques ;
- sensibiliser les collaborateurs aux risques de cybersécurité ;
- assurer la conformité aux exigences applicables, notamment le RGPD ;
- inscrire la sécurité de l'information dans une démarche d'amélioration continue.

La PSSI fixe plusieurs objectifs destinés à renforcer la sécurité du système d'information de BioMarket.

3.5 Principales mesures de sécurité

Afin d'atteindre ces objectifs, plusieurs mesures prioritaires ont été retenues.

Les principales actions concernent :

Mesure	**Finalité**
Authentification multifacteur (MFA)	Sécuriser les comptes à privilèges et les accès distants
Gestion des habilitations	Appliquer le principe du moindre privilège
Segmentation du réseau (VLAN)	Limiter la propagation d'une compromission
Sauvegardes régulières	Garantir la disponibilité des données
Gestion des incidents	Détecter et traiter rapidement les événements de sécurité
Gestion des changements	Encadrer les évolutions du système d'information

Mesure	Finalité
Sensibilisation des utilisateurs	Réduire les risques liés aux erreurs humaines
Supervision et détection (EDR/SIEM)	Améliorer la détection des menaces et des incidents.

Ces mesures répondent aux besoins de sécurité identifiés dans le cadre du projet et seront précisées et priorisées sur la base de l'analyse des risques. Ces mesures sont déclinées dans des règles et procédures opérationnelles afin d'assurer leur application au quotidien.

3.6 Gouvernance et responsabilités

La PSSI précise les responsabilités des différents acteurs intervenant dans le SMSI.

La Direction Générale définit les orientations stratégiques et valide les principales décisions. La DSI assure le déploiement des mesures techniques, pilote les infrastructures et coordonne les actions de sécurité. Le DPO veille au respect des obligations relatives à la protection des données personnelles, tandis que les responsables métiers participent à l'application des règles de sécurité dans leurs services.

Les collaborateurs sont responsables de l'utilisation des ressources informatiques mises à leur disposition et doivent respecter les règles définies par la PSSI ainsi que la charte informatique. Les prestataires, notamment Iron4Software, sont soumis aux exigences de sécurité prévues dans leurs contrats.

3.7 Processus de sécurité

La PSSI est déclinée en **règles et procédures opérationnelles** afin de permettre l'application concrète des exigences de sécurité dans les activités quotidiennes de BioMarket.

Les principaux processus formalisés concernent :

Processus / document	Finalité
Gestion des habilitations	Maîtriser les droits d'accès et appliquer le principe du moindre privilège
Gestion des incidents	Détecter, déclarer, traiter et suivre les incidents de sécurité
Gestion des changements	Encadrer les modifications apportées au système d'information
Classification des actifs informationnels	Adapter le niveau de protection à la sensibilité des informations
Sensibilisation des collaborateurs	Réduire les risques liés au facteur humain
Charte informatique	Formaliser les règles d'utilisation des ressources informatiques
Matrice RACI sécurité	Définir les responsabilités des différents acteurs

Ces documents complètent la PSSI et permettent de passer des principes de sécurité à leur **mise en œuvre opérationnelle**. Ils sont présentés dans les **Annexes C1 à C7**.

La mise en œuvre de ces procédures devra être suivie au moyen de contrôles et d'indicateurs afin de vérifier leur application et leur efficacité.

3.8 Pilotage et amélioration continue

Le SMSI est piloté au moyen d'indicateurs de performance présentés lors des réunions du comité de pilotage et des revues de direction.

Les principaux indicateurs suivis concernent notamment le déploiement du MFA, les incidents de sécurité, la réalisation des sauvegardes, les revues des habilitations et les actions de sensibilisation. Ces indicateurs permettent de mesurer l'efficacité des mesures mises en œuvre et d'identifier les actions d'amélioration nécessaires.

3.9 Conclusion

L'élaboration de la Politique de Sécurité du Système d'Information constitue une étape essentielle du projet de certification ISO/IEC 27001 de BioMarket. Elle formalise les engagements de la Direction, définit les objectifs du SMSI, précise les responsabilités des acteurs et présente les principales mesures de sécurité destinées à protéger les actifs informationnels de l'entreprise.

Cette politique fournit un cadre commun pour l'ensemble des collaborateurs et constitue le document de référence sur lequel s'appuient les procédures opérationnelles, les actions de sensibilisation et les dispositifs de contrôle. Sa mise en œuvre contribue à renforcer la gouvernance de la sécurité, à améliorer la conformité réglementaire et à préparer BioMarket à une future certification ISO/IEC 27001.

Le document complet de la Politique de Sécurité du Système d'Information est présenté en Annexe C.

Chapitre 4 - Analyse des risques

4.1 Objectif de l'analyse

Dans le cadre de la mise en œuvre du Système de Management de la Sécurité de l'Information (SMSI), une analyse des risques a été réalisée afin d'identifier les menaces susceptibles d'affecter les actifs critiques de BioMarket et de définir les mesures de sécurité les plus adaptées.

Cette analyse constitue une étape essentielle de la démarche ISO/IEC 27001. Elle permet d'évaluer les risques pesant sur le système d'information et de justifier les mesures retenues dans la Politique de Sécurité du Système d'Information (PSSI), le futur Plan de Continuité d'Activité (PCA) ainsi que le plan d'actions de sécurité.

Pour cette étude, la méthode **EBIOS Risk Manager (EBIOS RM)**, recommandée par l'ANSSI et compatible avec les exigences de la norme ISO/IEC 27001, a été retenue. Cette méthode permet d'adopter une approche orientée risques en tenant compte des activités métiers, des actifs critiques, des menaces et des interactions avec l'écosystème de l'entreprise.

La version détaillée de cette analyse est présentée en **Annexe D**.

4.2 Périmètre de l'analyse

L'analyse des risques porte sur le périmètre défini pour le SMSI, comprenant les infrastructures informatiques, les applications métiers, les données sensibles et les utilisateurs de BioMarket.

Les principaux éléments étudiés sont :

- le siège social et les magasins ;
- l'Active Directory et les serveurs ;
- les équipements réseau ;
- le stockage local et le stockage Cloud ainsi que les mécanismes de sauvegarde et de restauration à mettre en place
- les données clients, ressources humaines et commerciales ;
- les applications métiers ;
- les échanges entre le SI interne et la plateforme e-commerce via les API REST sécurisées ;
- les relations avec les prestataires, notamment Iron4Software.

La plateforme e-commerce constitue un composant du système d'information de BioMarket et est intégrée au périmètre de l'analyse des risques et du SMSI. Bien qu'elle soit développée et hébergée par Iron4Software sur une infrastructure PaaS, les exigences de sécurité applicables à la plateforme, aux données traitées et aux échanges avec le SI interne sont prises en compte dans l'analyse. L'infrastructure interne et les composants physiques administrés directement par Iron4Software restent hors du périmètre de responsabilité de BioMarket.

L'analyse porte notamment sur les valeurs métier critiques de BioMarket et les biens supports nécessaires à leur fonctionnement. Les valeurs métier comprennent notamment la vente de produits biologiques, la gestion des commandes et des stocks, la gestion financière, la relation client et la plateforme e-commerce. Les biens supports comprennent notamment l'Active Directory, les serveurs,

les postes de travail, les équipements réseau, les stockages local et Cloud, les applications métiers et les données clients, RH, commerciales et financières. Le détail de cette identification est présenté en Annexe D.

4.3 Principaux risques identifiés

L'analyse EBIOS RM a d'abord permis d'identifier les événements redoutés affectant les valeurs métier, puis de construire des scénarios stratégiques et opérationnels à partir des sources de risque, des parties prenantes et des biens supports concernés. La vraisemblance des scénarios opérationnels et la gravité des conséquences ont ensuite été évaluées afin de déterminer le niveau de risque.

L'application de la méthode EBIOS Risk Manager a permis d'identifier et de hiérarchiser quatre risques principaux susceptibles d'affecter les activités et le système d'information de BioMarket.

Risque	**Vraisemblance**	**Gravité**	**Niveau**	**Priorité**
Compromission d'un compte administrateur	Très vraisemblable	Critique	**Critique**	**1**
Attaque par rançongiciel	Très vraisemblable	Critique	**Critique**	**2**
Compromission d'Iron4Software	Très vraisemblable	Grave	**Critique**	**3**
Fuite de données personnelles	Vraisemblable	Critique	**Élevé**	**4**

La cotation repose sur le croisement de la vraisemblance, évaluée de V1 à V4, et de la gravité, évaluée de G1 à G4. Cette méthode permet de hiérarchiser les risques et de définir les priorités de traitement. La matrice de cotation détaillée est présentée en Annexe D.

Les trois premiers risques constituent les principales priorités de traitement en raison de leur niveau de risque critique. La fuite de données personnelles représente également un risque important et fait l'objet de mesures spécifiques de réduction.

Ces scénarios présentent un impact élevé sur la continuité des activités, la protection des données et la conformité réglementaire de l'entreprise.

4.4 Mesures de traitement retenues

À l'issue de l'analyse, plusieurs mesures de sécurité ont été retenues afin de réduire les risques identifiés.

Les principales actions concernent :

Mesure	**Objectif**
Généralisation du MFA	Renforcer la sécurité des comptes sensibles
Revue des habilitations	Garantir le respect du principe du moindre privilège
Sensibilisation des collaborateurs	Réduire les risques liés aux erreurs humaines
Renforcement des sauvegardes	Assurer la disponibilité des données
Contrôle des accès des prestataires	Sécuriser les interventions externes
Journalisation et supervision	Détecter rapidement les incidents de sécurité

Mesure	Objectif
Gestion des changements	Encadrer les évolutions du système d'information

Ces mesures ont été intégrées à la PSSI et serviront de base au plan d'actions du SMSI.

4.5 Résultats de l'analyse

L'analyse met en évidence que BioMarket dispose déjà d'un socle technique de sécurité (Active Directory centralisé, une organisation du réseau reposant notamment sur des VLAN, VPN SSL et authentification multifacteur pour les comptes à privilèges). Toutefois, plusieurs axes d'amélioration ont été identifiés, notamment en matière de gouvernance, de gestion des habilitations, de sensibilisation des utilisateurs et de formalisation des processus.

Les principaux risques identifiés concernent la compromission de l'Active Directory, les attaques par rançongiciel, la fuite de données, la compromission d'un prestataire, les erreurs humaines ainsi que l'absence ou l'insuffisance de dispositifs de sauvegarde et de restauration.

Les mesures de traitement retenues portent notamment sur la généralisation du MFA, la revue des habilitations, la sensibilisation des utilisateurs, le déploiement d'un EDR, la journalisation centralisée, le contrôle des accès des prestataires et la mise en place de mécanismes de sauvegarde et de tests de restauration.

Les résultats de cette analyse constituent la base des mesures de sécurité définies dans la PSSI et des dispositions de continuité présentées dans le PCA.

4.6 Conclusion

L'analyse des risques constitue un élément central du projet de mise en place du SMSI. En s'appuyant sur la méthode EBIOS Risk Manager, elle a permis d'identifier les risques majeurs auxquels BioMarket est exposée et de définir les mesures de sécurité nécessaires pour les maîtriser.

Les conclusions de cette analyse alimentent directement la Politique de Sécurité du Système d'Information, le plan d'actions de sécurité ainsi que les futurs dispositifs de continuité d'activité. Elles constituent également un support essentiel pour le pilotage du SMSI et son amélioration continue.

L'analyse détaillée des risques, incluant les cinq ateliers EBIOS Risk Manager, est présentée en Annexe D.

Chapitre 5 – Élaboration du Plan de Continuité d'Activité (PCA)

5.1 Identification des exigences essentielles à garantir

L'objectif de cette étape est d'identifier les activités indispensables au fonctionnement de BioMarket ainsi que les ressources et services nécessaires à leur maintien en cas d'incident majeur. Cette analyse s'appuie sur le contexte de l'entreprise, la cartographie du système d'information, l'analyse des risques réalisée précédemment et les résultats de l'Analyse d'Impact sur l'Activité (BIA).

Les activités prioritaires identifiées sont les suivantes :

Activité critique	**Criticité**	**Impact en cas d'interruption**
Vente en magasin	Critique	Arrêt ou forte dégradation de l'activité commerciale
Gestion de la plateforme e-commerce	Critique	Interruption des ventes en ligne et perte de chiffre d'affaires
Gestion des stocks	Critique	Ruptures de stock et perturbation des approvisionnements
Gestion des données clients	Critique	Indisponibilité des données et risque réglementaire
Commandes fournisseurs	Élevée	Retards d'approvisionnement et perturbation des livraisons
Communications internes	Élevée	Difficultés de coordination entre les sites et les équipes

Ressources clés

La continuité de ces activités repose notamment sur les ressources suivantes :

- l'infrastructure réseau du siège et des magasins ;
- les services d'authentification Active Directory ainsi que les services DNS et DHCP ;
- les serveurs et applications métiers ;
- les bases de données contenant les informations commerciales et les données clients ;
- les mécanismes de sauvegarde et de restauration ;
- les connexions réseau et VPN entre les différents sites ;
- les équipes informatiques et les responsables métiers ;
- les prestataires critiques, notamment Iron4Software pour la plateforme e-commerce.

Services prioritaires

Les services devant être maintenus ou rétablis en priorité sont :

- l'encaissement en magasin ;
- l'accès aux applications de gestion des stocks ;
- l'accès aux données clients et fournisseurs ;
- les communications internes ;
- les services d'authentification ;

- les accès réseau sécurisés entre les différents sites ;
- la plateforme e-commerce et ses échanges avec le système d'information interne.

Objectifs de continuité

Afin de répondre aux exigences du projet, les objectifs de reprise suivants ont été retenus :

- **RTO (Recovery Time Objective) : 4 heures maximum** ;
- **RPO (Recovery Point Objective) : 12 heures maximum**.

Le RTO correspond au délai maximal acceptable pour rétablir une activité ou un service critique après une interruption. Le RPO correspond à la perte maximale de données acceptable entre le dernier point de récupération exploitable et la survenue de l'incident.

Ces valeurs constituent des **objectifs de continuité**. Leur atteinte dépendra de la mise en œuvre effective des mécanismes de sauvegarde, de restauration, des procédures et des ressources prévues dans le PCA.

5.2 Analyse des scénarios et des vulnérabilités

Cette étape consiste à identifier les principaux événements susceptibles d'interrompre les activités critiques de BioMarket et à déterminer les vulnérabilités ainsi que les points de défaillance pouvant aggraver leurs conséquences.

Cette analyse s'appuie sur les résultats de l'analyse des risques réalisée selon la méthode EBIOS Risk Manager et sur les activités et ressources critiques identifiées dans la BIA. Les scénarios retenus permettent de définir les mesures de continuité et de reprise adaptées.

Scénarios d'incidents retenus

Scénario	**Conséquences potentielles**
Compromission d'un compte administrateur	Compromission de ressources critiques, notamment Active Directory et les serveurs, pouvant entraîner une interruption des activités
Attaque par rançongiciel	Indisponibilité des serveurs, chiffrement des données et interruption des activités
Compromission d'Iron4Software	Perturbation ou compromission des services liés à la plateforme e-commerce
Fuite de données personnelles	Indisponibilité ou divulgation de données clients, conséquences réglementaires et atteinte à l'image
Panne matérielle d'un serveur	Interruption des applications métiers et indisponibilité temporaire de services
Coupure de la connexion Internet	Perturbation des échanges externes et de l'accès aux services dépendants d'Internet
Défaillance du réseau interne	Rupture des communications entre les magasins et le siège
Sinistre physique	Indisponibilité ou perte d'équipements et interruption de l'activité sur le site concerné

Scénario	Conséquences potentielles
Erreur humaine	Suppression de données, mauvaise configuration ou interruption involontaire d'un service

Vulnérabilités identifiées

L'analyse des risques met en évidence plusieurs vulnérabilités susceptibles de favoriser la réalisation de ces scénarios :

- dépendance à certains serveurs et services critiques ;
- contrôle des accès privilégiés et des accès des prestataires à renforcer ;
- privilèges potentiellement excessifs sur certains comptes ;
- sensibilisation des utilisateurs à renforcer face aux risques de phishing et aux cybermenaces ;
- risques liés aux erreurs de configuration et aux erreurs humaines ;
- dépendance aux mécanismes de sauvegarde et de restauration pour assurer la reprise des données ;
- dépendance à un prestataire externe pour le développement de la plateforme e-commerce et nécessité de maîtriser les accès qui lui sont accordé ;
- dépendance aux communications réseau entre les différents sites.

Points de défaillance critiques

Les principaux points de défaillance à anticiper sont les suivants :

- les serveurs d'authentification, notamment **Active Directory** ;
- les serveurs et applications nécessaires à la gestion des stocks et aux activités métiers ;
- les connexions réseau entre les magasins et le siège ;
- les données clients et les données nécessaires aux activités commerciales ;
- les mécanismes de sauvegarde et de restauration ;
- les accès privilégiés aux ressources du système d'information ;
- les interfaces et échanges liés à la plateforme e-commerce ;
- les prestataires indispensables au fonctionnement ou au maintien des services critiques.

L'identification de ces scénarios, vulnérabilités et points de défaillance constitue la base de la définition des mesures organisationnelles et techniques du PCA. Elle permet notamment de déterminer les priorités de reprise, les responsabilités à mobiliser et les procédures à appliquer en fonction du type d'incident.

5.3 Élaboration du Plan de Continuité d'Activité (PCA)

À partir des activités critiques identifiées dans la BIA et des scénarios d'incidents étudiés précédemment, BioMarket a défini un Plan de Continuité d'Activité visant à maintenir ou à rétablir les activités essentielles de l'entreprise en cas d'incident majeur.

Le PCA couvre les principales activités et ressources nécessaires à la continuité de l'activité, notamment les ventes en magasin, la plateforme e-commerce, la gestion des stocks, les données clients, les commandes fournisseurs et les communications internes.

Le dispositif défini repose sur des mesures organisationnelles et techniques permettant de réduire les conséquences d'une interruption et d'assurer une reprise maîtrisée des services prioritaires.

Organisation de la continuité

La gestion de crise repose sur une organisation adaptée aux responsabilités de BioMarket :

- Direction Générale : prend les décisions stratégiques, valide les décisions majeures et peut déclencher le PCA ;
- DSI / Référent SSI : coordonne la réponse technique, le rétablissement des services et le suivi des actions ;
- Équipe informatique : assure les actions techniques nécessaires à la continuité et à la reprise du système d'information ;
- Administrateurs systèmes et réseau : interviennent sur les infrastructures, les systèmes et les communications ;
- DPO : intervient lorsque l'incident concerne des données personnelles ou implique des obligations réglementaires ;
- Responsables métiers : identifient les priorités opérationnelles et contribuent à la reprise des activités ;
- Prestataires critiques : sont mobilisés lorsque leurs services sont nécessaires à la continuité ou à la restauration.

Cette organisation est cohérente avec la gouvernance retenue dans le reste du projet.

Mesures de continuité

Les principales mesures prévues par le PCA portent notamment sur :

- la définition des procédures de gestion de crise et d'escalade ;
- l'identification des responsables et des ressources à mobiliser ;
- la mise en œuvre de mécanismes de sauvegarde et de restauration ;
- la restauration priorisée des services critiques ;
- la mise en place de solutions de communication alternatives en cas d'indisponibilité du réseau ;
- la coordination avec les prestataires critiques ;
- la conservation d'un journal de crise permettant de suivre les événements et les décisions ;
- la réalisation de tests et d'exercices afin de vérifier l'efficacité du dispositif.

Objectifs de reprise

Le PCA fixe les objectifs de continuité suivants :

- RTO ≤ 4 heures
- RPO ≤ 12 heures

Ces objectifs constituent les cibles de reprise retenues pour les activités et services critiques. Leur atteinte doit être vérifiée au moyen des procédures, mécanismes de restauration et tests prévus dans le PCA.

Prise en compte de la plateforme e-commerce

La plateforme e-commerce est intégrée au périmètre de continuité de BioMarket puisqu'elle constitue un composant du système d'information et participe directement à l'activité commerciale.

La continuité de ce service nécessite notamment de prendre en compte les échanges avec le système d'information interne ainsi que la dépendance à Iron4Software.

En revanche, l'infrastructure PaaS et les composants internes administrés directement par Iron4Software restent hors du périmètre de responsabilité de BioMarket. Les engagements de continuité du prestataire doivent donc être pris en compte dans la gestion des services externalisés.

Référence au PCA complet

Le PCA détaillé, comprenant les procédures de gestion de crise, les responsabilités, les stratégies de continuité, les procédures opérationnelles et les fiches réflexes associées aux principaux scénarios d'incident, est présenté en Annexe E – Plan de Continuité d'Activité.

5.4 Réalisation des tests du Plan de Continuité d'Activité

Afin de vérifier l'efficacité du dispositif de continuité, BioMarket prévoit la réalisation régulière de tests et d'exercices portant sur les différents composants du PCA. Ces tests permettent de vérifier l'applicabilité des procédures, la disponibilité des ressources nécessaires, la coordination des acteurs et l'atteinte des objectifs de reprise définis.

Le programme de tests retenu est le suivant :

Test	Objectif détaillé	Fréquence	Responsable	Résultat attendu
Relecture documentaire	Vérifier l'actualisation du PCA, des procédures, des contacts et des responsabilités	Annuelle	DSI	Documentation à jour et informations opérationnelles valides
Exercice de gestion de crise	Vérifier l'organisation, l'escalade et la coordination des acteurs	Annuelle	DG / DSI	Cellule de crise activée et coordination conforme aux procédures
Test de restauration	Vérifier la capacité à restaurer les données et à contrôler leur intégrité	Semestrielle	DSI	Données restaurées et intégrité vérifiée
Simulation de cyberattaque	Évaluer la capacité de réaction face à une attaque et vérifier l'application des procédures	Annuelle	DSI	Procédures d'escalade et de réponse correctement appliquées

Test	Objectif détaillé	Fréquence	Responsable	Résultat attendu
Test de continuité des services	Vérifier la capacité à maintenir ou rétablir les services critiques dans les objectifs définis	Annuelle	DSI	RTO ≤ 4 h et RPO ≤ 12 h atteints

Les résultats de chaque exercice sont consignés et analysés afin d'identifier les écarts, difficultés ou améliorations nécessaires. Les actions correctives identifiées sont suivies jusqu'à leur réalisation et intégrées, lorsque nécessaire, aux mises à jour du PCA.

Le suivi des tests s'inscrit ainsi dans une démarche d'amélioration continue du dispositif de continuité.

5.5 Estimation des coûts de mise en œuvre

La mise en œuvre du dispositif de continuité nécessite des dépenses liées aux solutions techniques, à la sauvegarde et à la restauration, à la réalisation des tests et exercices ainsi qu'à la documentation et à la maintenance du PCA. Le budget prévisionnel associé au dispositif de continuité est estimé à 80 000 € HT.

Ce montant constitue un macro-chiffrage destiné à donner un ordre de grandeur des ressources nécessaires à la mise en œuvre du PCA. Les montants définitifs dépendront notamment des solutions techniques retenues, des prestataires sélectionnés et des modalités de mise en œuvre.

Poste de dépense	Éléments inclus	Coût estimatif HT
Sauvegarde et stockage externalisé	Mise en place / renforcement de la stratégie de sauvegarde, chiffrement et stockage externalisé	25 000 €
Tests et exercices PCA	Exercices de gestion de crise, tests de restauration, simulation de cyberattaque et tests de continuité	10 000 €
Mise en œuvre du PCA	Déploiement et configuration des procédures et dispositifs de continuité et de reprise	10 000 €
Solutions techniques de secours	Moyens nécessaires à la reprise des services critiques et à l'atteinte des objectifs RTO/RPO	30 000 €
Documentation et mise à jour	Documentation des procédures et mise à jour du PCA	5 000 €
Total		**80 000 € HT**

Chapitre 6 – Élaboration du plan d’actions de sécurité

6.1 Synthèse du plan d’actions de sécurité

Le plan d’actions de sécurité traduit les orientations de la Politique de Sécurité du Système d’Information (PSSI) et les résultats de l’analyse des risques en mesures concrètes visant à réduire les principaux risques identifiés pour BioMarket.

Les actions retenues couvrent principalement le **contrôle des accès**, la **protection des données**, la **détection des incidents**, la **sensibilisation des collaborateurs**, la **maîtrise des accès des prestataires** et le **renforcement de l’architecture réseau**.

Le plan comprend **11 actions**. Les mesures relatives au contrôle des accès portent notamment sur la généralisation de l’authentification multifacteur (MFA), la revue semestrielle des habilitations, le renforcement de la politique de mots de passe et le contrôle des accès des prestataires. Les mesures de protection des données comprennent notamment le chiffrement des postes portables et des sauvegardes.

Le plan prévoit également le déploiement d'une solution EDR, la centralisation des journaux de sécurité, la sensibilisation des collaborateurs, la formalisation de la gestion des changements ainsi que le renforcement de la segmentation réseau et l'isolation des serveurs critiques.

Les actions sont priorisées selon plusieurs critères : le niveau de risque identifié, l’impact sur les activités métiers et sur la sécurité de l’information, la faisabilité technique et organisationnelle, le coût de mise en œuvre et les éventuelles dépendances avec d’autres actions. Cette démarche permet de concentrer les efforts sur les mesures apportant la réduction de risque la plus importante.

Le coût estimatif global du plan d’actions de sécurité s’élève à 195 000 € HT. Le détail des coûts associés à chaque action est présenté dans l’Annexe F – Plan d’Actions de Sécurité.

Les actions contribuent enfin aux objectifs de conformité et de certification de BioMarket, notamment au regard de l’**ISO/IEC 27001:2022**, du **RGPD** et des exigences définies dans la PSSI.

6.2 Évaluation de l’impact, priorisation et coûts des actions

Les actions de sécurité sont priorisées selon leur niveau de risque, leur impact potentiel sur les activités de BioMarket et leur contribution à la réduction des risques identifiés. Les risques critiques font l’objet d’un traitement prioritaire.

Les actions sont classées selon l’échelle de priorité définie dans le plan d’actions de sécurité : P1 – Critique, P2 – Haute, P3 – Moyenne et P4 – Faible.

Les actions P1 – Critique sont traitées en priorité, car elles répondent aux risques critiques identifiés. Les actions P2 – Haute renforcent significativement le niveau de sécurité et sont mises en œuvre à court terme. Les actions P3 – Moyenne sont planifiées progressivement selon les ressources disponibles. Aucune action P4 – Faible n'est actuellement identifiée.

Le coût estimatif global du plan d'actions de sécurité est de 195 000 € HT. Ce montant constitue une estimation prévisionnelle et pourra être ajusté lors de la mise en œuvre en fonction des solutions retenues et des conditions de déploiement.

Priorité	Actions principales	Coût estimatif
P1 – Critique	A1 – MFA ; A2 – Revue des habilitations ; A3 – Politique de mots de passe ; A6 – EDR ; A11 – Segmentation et isolation des serveurs critiques	**90 000 €**
P2 – Haute	A4 – BitLocker ; A5 – Sauvegardes chiffrées ; A7 – SIEM ; A8 – Sensibilisation ; A9 – Accès prestataires	**100 000 €**
P3 – Moyenne	A10 – Gestion des changements	**5 000 €**
P4 – Faible	Aucune action actuellement identifiée	**0 €**
Total	**A1 à A11**	**195 000 € HT**

Comparaison budgétaire des solutions de sécurité

Afin de justifier les choix techniques retenus dans le cadre de la PSSI, plusieurs solutions ont été comparées pour les principaux besoins de sécurité. La comparaison prend en compte le niveau de protection apporté, les fonctionnalités couvertes, l'intégration dans l'architecture cible et le coût estimatif. Les montants des solutions alternatives sont des estimations indicatives destinées à permettre l'arbitrage budgétaire. Les coûts des solutions retenues sont ceux inscrits dans le plan d'actions de sécurité.

Besoin	Solution envisagée	Niveau	Coût estimatif HT	Choix BioMarket
Authentification	MFA limité aux comptes privilégiés	Standard	8 000 €	
	MFA généralisé	Renforcé	**15 000 €**	✓
Protection endpoints	Antivirus nouvelle génération	Standard	12 000 €	
	EDR postes + serveurs	Renforcé	**30 000 €**	✓
Supervision	Centralisation simple des journaux	Standard	15 000 €	
	SIEM centralisé	Renforcé	**30 000 €**	✓
Sauvegardes	Sauvegardes locales	Standard	12 000 €	
	Sauvegardes chiffrées	Renforcé	**25 000 €**	✓
Accès distants	VPN seul	Standard	8 000 €	
	VPN + MFA + journalisation	Renforcé	**15 000 €**	✓
Segmentation réseau	VLAN simples	Standard	12 000 €	
	VLAN + filtrage inter-zones + UTM	Renforcé	**20 000 €**	✓

Les montants présentés sont des estimations indicatives par besoin et ne sont pas directement cumulables. Le budget de référence des mesures de sécurité est celui du plan d'actions A1 à A11, soit 195 000 € HT.

6.3 Intégration des exigences ISO 27001 et RGPD

Le plan d'actions de sécurité prend en compte les exigences applicables au système d'information de BioMarket, notamment celles de la norme ISO/IEC 27001:2022 et du RGPD. Ces référentiels constituent des éléments de référence pour définir et prioriser les mesures de sécurité.

Les principales correspondances sont les suivantes :

Exigence / objectif	**Mesures du plan d'actions**
ISO/IEC 27001 – maîtrise des accès	MFA, revue des habilitations, politique de mots de passe, gestion des accès prestataires
ISO/IEC 27001 – protection des informations	Chiffrement des postes et des sauvegardes, classification des actifs
ISO/IEC 27001 – gestion des incidents et détection	EDR, centralisation des journaux et SIEM
ISO/IEC 27001 – maîtrise des changements	Formalisation de la gestion des changements
ISO/IEC 27001 – sécurité des fournisseurs	Encadrement des accès et exigences de sécurité applicables aux prestataires
RGPD – sécurité des données personnelles	Contrôle des accès, chiffrement, sauvegardes, EDR et sensibilisation
RGPD – protection des données	Limitation des accès, classification des informations et mesures de protection adaptées aux risques
RGPD – gestion des violations	Détection, journalisation et traitement des incidents de sécurité

Le plan d'actions traduit ainsi les exigences réglementaires et les objectifs du SMSI en mesures concrètes et suivies. Il contribue à réduire les risques identifiés tout en préparant BioMarket à un futur audit de certification ISO/IEC 27001. L'Annexe F confirme que le plan prend notamment en compte l'ISO/IEC 27001:2022, le RGPD, les recommandations de l'ANSSI et la PSSI de BioMarket.

6.4 Évolution vers l'architecture cible

L'architecture cible traduit techniquement les mesures de sécurité définies dans le plan d'actions. Elle vise à renforcer la protection du système d'information tout en conservant les besoins d'accès aux services métiers.

Les principales évolutions par rapport à l'architecture actuelle sont :

- renforcement de la segmentation réseau par la création de VLAN dédiés ;
- isolation des serveurs critiques dans un VLAN spécifique ;

- création d'un VLAN dédié aux sauvegardes afin de limiter leur exposition ;
- mise en place d'une DMZ pour les services exposés, notamment l'application/API e-commerce ;
- renforcement du filtrage inter-zones au moyen du pare-feu UTM ;
- sécurisation des accès distants par VPN SSL et MFA ;
- encadrement des accès privilégiés des prestataires, notamment Iron4Software ;
- déploiement d'une solution EDR sur les postes utilisateurs et les serveurs afin de renforcer la détection des comportements malveillants et de contribuer à la réponse aux incidents ;
- centralisation des journaux de sécurité dans un SIEM afin d'améliorer la détection et la traçabilité.

Cette architecture cible constitue la traduction technique des principales actions du plan de sécurité et permet notamment de réduire les risques de compromission des comptes, de propagation d'un rançongiciel et d'accès non autorisés aux ressources critiques.

6.5 Flux et accès sécurisés

Les flux réseau de l'architecture cible sont définis selon le principe du moindre privilège. Les communications sont autorisées uniquement lorsqu'elles sont nécessaires au fonctionnement des services ou aux activités d'administration.

Les principaux flux retenus sont les suivants :

Source	**Destination**	**Flux / protocole**	**Mesure de sécurité**
Utilisateurs nomades	FortiGate	VPN SSL / 443	MFA
Iron4Software	Ressources autorisées	VPN sécurisé / 443	MFA + journalisation
Internet	DMZ	HTTPS / 443	Filtrage UTM
PaaS	Application/API BioMarket	HTTPS / 443	Filtrage contrôlé
Salariés	Cloud Storage	HTTPS / 443	Contrôle par le pare-feu
VLAN utilisateurs	VLAN serveurs critiques	Aucun par défaut	Interdiction sauf besoin explicitement autorisé
Serveurs	VLAN sauvegardes	Flux de sauvegarde	Flux limités aux besoins de sauvegarde/restauration
Équipements et serveurs	SIEM	Collecte des journaux	Centralisation et traçabilité

Les accès aux ressources critiques sont ainsi limités aux flux nécessaires. Les accès privilégiés et les accès distants sont renforcés par l'authentification multifacteur et font l'objet d'une journalisation afin de faciliter la détection et l'analyse des événements de sécurité.

6.6 Architecture cible – Cartographie

L'architecture cible de BioMarket traduit les mesures de sécurité définies dans le plan d'actions et vise à renforcer la segmentation, le contrôle des flux et la protection des ressources critiques.

Elle repose notamment sur :

- un pare-feu UTM FortiGate assurant le filtrage des communications entre les différentes zones ;
- une segmentation par VLAN des utilisateurs, serveurs, infrastructures, équipements d'administration, serveurs critiques et sauvegardes ;
- une DMZ dédiée aux services exposés, notamment l'application/API e-commerce ;
- un VLAN dédié aux serveurs critiques (VLAN 70) afin de limiter leur exposition aux autres réseaux ;
- un VLAN dédié aux sauvegardes (VLAN 80) afin de renforcer leur isolation ;
- un VPN SSL avec MFA pour les accès distants et les accès privilégiés ;
- un SIEM permettant de centraliser les journaux de sécurité ;
- le déploiement d'une solution EDR sur les postes utilisateurs et les serveurs afin d'assurer la détection des comportements malveillants et de contribuer à la réponse aux incidents ;
- le maintien des échanges avec les environnements Cloud et PaaS selon les flux nécessaires au fonctionnement de la plateforme.

Les événements de sécurité pertinents issus de l'EDR peuvent être transmis au SIEM afin de corréler les événements provenant des terminaux, des serveurs et des équipements de sécurité.

La cartographie permet ainsi de visualiser les différentes zones de sécurité, les équipements concernés ainsi que les principaux flux entre les environnements.

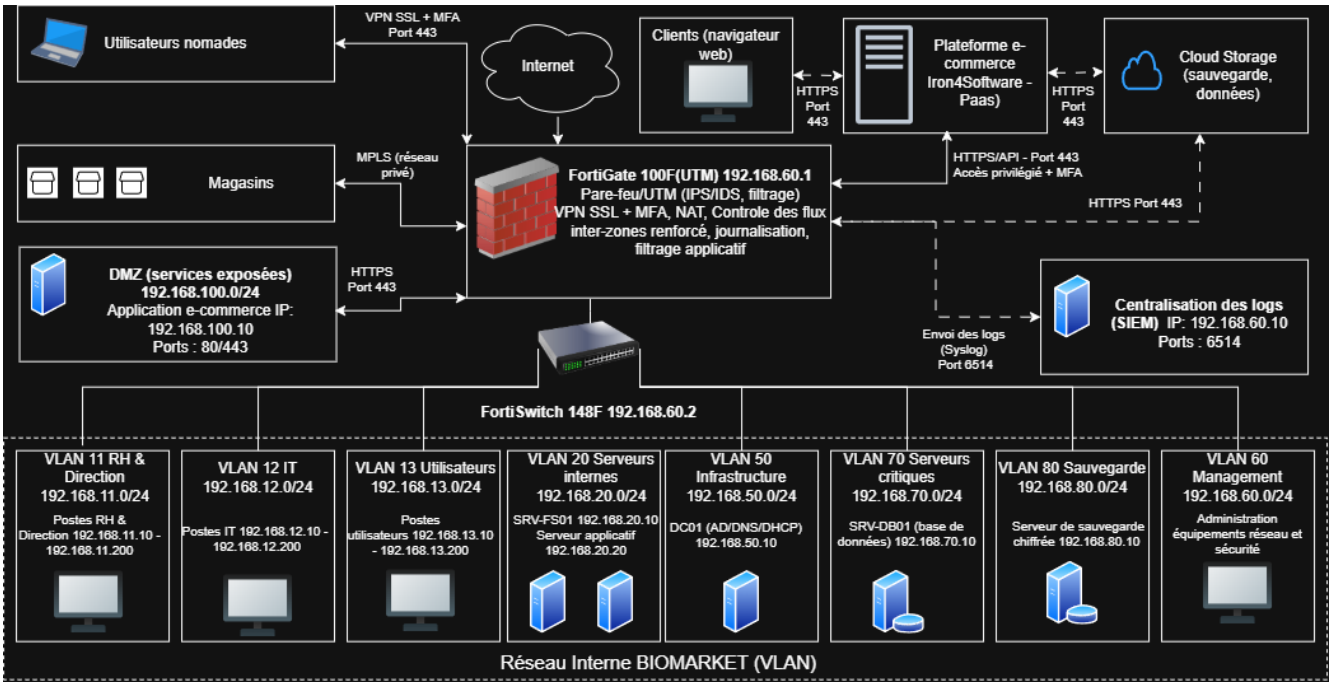


Figure 2 – Architecture cible de BioMarket

6.7 Justification de l'architecture cible

L'architecture cible répond aux principaux risques identifiés dans l'analyse de risques et aux actions définies dans le plan d'actions de sécurité.

Les principales évolutions sont justifiées de la manière suivante :

Évolution	**Justification**
Segmentation par VLAN	Limiter les communications entre les différents environnements et réduire les possibilités de mouvements latéraux en cas de compromission.
Isolation des serveurs critiques	Protéger les ressources les plus sensibles et limiter leur exposition aux postes utilisateurs.
VLAN dédié aux sauvegardes	Renforcer la résilience du SI face aux incidents, notamment aux rançongiciels.
DMZ	Isoler les services nécessitant des communications avec des réseaux externes du reste du réseau interne.
Pare-feu UTM	Contrôler les flux entre les différentes zones et appliquer des règles de filtrage adaptées.
Déploiement d'un EDR	Renforcer la protection des postes utilisateurs et des serveurs contre les comportements malveillants, notamment les malwares et rançongiciels, et améliorer les capacités de détection et de réponse aux incidents.
VPN + MFA	Renforcer la sécurité des accès distants et des accès privilégiés.
SIEM	Améliorer la détection, la supervision et la traçabilité des événements de sécurité.

Cette architecture permet ainsi de répondre aux principales actions du plan de sécurité, tout en conservant les communications nécessaires au fonctionnement de la plateforme e-commerce et aux activités de BioMarket.

6.8 Note de cadrage du projet

6.8.1 Objectifs du projet

Le projet vise à mettre en œuvre le plan d'actions de sécurité défini à partir de la PSSI et de l'analyse des risques de BioMarket.

Les principaux objectifs sont :

- réduire les risques liés aux comptes privilégiés et aux accès distants ;
- renforcer la protection des données et des ressources critiques ;
- améliorer la détection et la traçabilité des événements de sécurité ;
- renforcer la résilience du SI, notamment face aux rançongiciels ;
- améliorer la conformité du système d'information avec les exigences du SMSI, de l'ISO/IEC 27001 et du RGPD.

6.8.2 Démarche de sécurité

La démarche repose sur une approche progressive fondée sur les risques. Les actions sont priorisées selon leur niveau de criticité, leur impact sur le système d'information, leur faisabilité technique et organisationnelle ainsi que les ressources nécessaires.

La mise en œuvre s'appuie notamment sur :

- le renforcement des contrôles d'accès et du MFA ;
- la protection des postes et des données ;
- la segmentation et l'isolation du réseau ;
- Déploiement d'une solution EDR sur les postes utilisateurs et les serveurs afin de détecter les comportements malveillants et de contribuer à la réponse aux incidents ;
- la sécurisation des sauvegardes ;
- la centralisation des journaux et la supervision ;
- la sensibilisation des collaborateurs ;
- la maîtrise des accès des prestataires.

Cette démarche permet d'assurer la cohérence entre les risques identifiés, les mesures de sécurité retenues et l'architecture cible.

6.8.3 Ressources nécessaires

Type de ressources	Ressources mobilisées
Humaines	DG, DSI / Référent SSI, équipe informatique, DPO (à désigner), consultant cybersécurité, utilisateurs
Techniques	Pare-feu UTM, segmentation VLAN, MFA, EDR, SIEM, solution de sauvegarde, chiffrement
Financières	Budget dédié à la mise en œuvre du plan d'actions

Le budget prévisionnel du plan d'actions de sécurité s'élève à 195 000 € HT. Les dépenses seront engagées progressivement selon les priorités définies, les risques identifiés et les contraintes du projet. ***Le détail des coûts associés à chaque action est présenté dans l'Annexe F – Plan d'Actions de Sécurité.***

6.9 Planning et mise en œuvre du projet

6.9.1 Méthodologie de gestion du projet

La mise en œuvre du plan d'actions repose sur une approche progressive et priorisée selon les risques identifiés.

Les actions sont organisées en tenant compte de leur niveau de priorité, de leur impact sur la sécurité du système d'information, de leur faisabilité technique et organisationnelle ainsi que des éventuelles dépendances entre actions.

La démarche retenue est la suivante :

1. Prioriser les actions à partir des risques identifiés et des objectifs de la PSSI ;
2. Planifier les actions en tenant compte des dépendances techniques et organisationnelles ;
3. Mettre en œuvre les mesures de sécurité et déployer les procédures associées auprès des équipes concernées ;
4. Vérifier la réalisation, l'application et l'efficacité des mesures et procédures mises en place ;
5. Suivre et améliorer le dispositif au travers des indicateurs et des revues de sécurité.

6.9.2 Planning de mise en œuvre

Phase	Actions principales	Priorité
Phase 1 – Sécurisation des accès	A1 – MFA ; A2 – Revue des habilitations ; A3 – Politique de mots de passe	P1 – Critique
Phase 2 – Protection des postes et détection	A6 – Déploiement d'un EDR	P1 – Critique
Phase 3 – Segmentation et isolation du réseau	A11 – Segmentation réseau et isolation des serveurs critiques	P1 – Critique
Phase 4 – Protection des données	A4 – BitLocker ; A5 – Sauvegardes chiffrées	P2 – Haute
Phase 5 – Supervision et détection	A7 – Centralisation des journaux / SIEM	P2 – Haute
Phase 6 – Facteur humain et prestataires	A8 – Sensibilisation ; A9 – Contrôle des accès prestataires	P2 – Haute
Phase 7 – Maîtrise des changements	A10 – Gestion des changements	P3 – Moyenne

Le planning détaillé, les responsables, les échéances et les coûts associés sont présentés dans l'Annexe F– Plan d'Actions de Sécurité et dans les documents de pilotage du projet.

6.9.3 Suivi du projet et indicateurs

Le suivi du projet est assuré par la DSI / Référent SSI dans le cadre du pilotage du SMSI. Un tableau de bord permet de suivre l'avancement des actions, les éventuels retards, les ressources mobilisées et l'évolution des principaux indicateurs de sécurité.

Indicateur	Objectif
Taux d'avancement des actions	Mesurer la progression globale du plan
Taux de réalisation des actions prioritaires	Vérifier le traitement des priorités
Nombre d'actions en retard	Identifier les écarts de planning
Budget consommé	Suivre les dépenses du projet
Taux de déploiement du MFA	Mesurer la généralisation du MFA
Taux de participation aux sensibilisations	Suivre la couverture des collaborateurs
Nombre d'incidents de sécurité	Suivre l'évolution des événements de sécurité
Taux de conformité des habilitations	Vérifier la maîtrise des droits d'accès

Les résultats du suivi sont utilisés pour identifier les écarts et définir, si nécessaire, des actions correctives. Ils alimentent également le processus d'amélioration continue du SMSI.

6.9.4 Livrables et documents de suivi

La mise en œuvre du projet s'appuie sur les principaux livrables permettant de formaliser les mesures de sécurité, de suivre leur réalisation et de préparer les étapes suivantes du SMSI.

Documents à fournir dans le cadre de la livraison du projet

- Rapport final ;
- étude du contexte ;
- plan projet SMSI ;
- PSSI ;
- procédures de sécurité ;
- analyse des risques ;
- PCA ;
- plan d'actions ;
- architecture actuelle ;
- architecture cible ;
- planning ;
- tableau de bord ;
- supports de preuve et de suivi.

Ces livrables sont maintenus et mis à jour au cours du projet afin d'assurer la traçabilité des décisions, des actions réalisées et des écarts constatés.

6.10 Conclusion

Cette étape a permis de traduire les orientations de la PSSI et les résultats de l'analyse des risques en un plan d'actions de sécurité structuré et priorisé.

Les actions retenues couvrent notamment la maîtrise des accès, la protection des données, la sécurisation des postes, la détection des incidents, la sensibilisation des collaborateurs, la gestion des prestataires et le renforcement de l'architecture réseau.

L'étude de l'architecture cible permet également de définir les principales évolutions techniques nécessaires : segmentation réseau, isolation des serveurs critiques, sécurisation des sauvegardes, DMZ, filtrage UTM, VPN, MFA et centralisation des journaux.

Enfin, la note de cadrage, le planning et les indicateurs de suivi définissent les conditions nécessaires à la mise en œuvre et au pilotage des actions dans le cadre du SMSI.

L'ensemble de ces éléments constitue une base pour poursuivre la démarche de mise en œuvre, de suivi et d'amélioration continue du SMSI de BioMarket.

Conclusion générale

La démarche menée dans le cadre de ce projet a permis de proposer à BioMarket une approche globale et structurée de la cybersécurité, adaptée à son contexte, à ses enjeux métiers et à son projet de transformation numérique.

L'analyse du contexte et du système d'information a permis d'identifier les principaux actifs, processus et parties prenantes concernés, ainsi que les besoins de sécurité associés. La veille et l'analyse OSINT ont également permis de mettre en évidence les enjeux liés à l'évolution des menaces et à l'exposition numérique de l'entreprise.

Sur cette base, le projet a permis de définir le **périmètre du SMSI**, sa gouvernance et ses objectifs, puis de formaliser une **PSSI** précisant les principes et responsabilités applicables à la sécurité de l'information. L'analyse des risques menée selon **EBIOS Risk Manager** a ensuite permis d'identifier et de hiérarchiser les principaux scénarios de risque, notamment ceux liés à la compromission des comptes privilégiés, aux rançongiciels, à la protection des données personnelles et aux accès du prestataire Iron4Software.

La démarche a également intégré les enjeux de **continuité d'activité**, avec la définition des besoins de disponibilité et des mesures de continuité associées. Le plan d'actions de sécurité traduit ensuite les résultats de ces travaux en mesures concrètes et priorisées, couvrant notamment les accès, le chiffrement, la protection des postes, la supervision, la sensibilisation, la gestion des prestataires et la segmentation du réseau.

Enfin, l'architecture cible proposée apporte une réponse technique aux principaux risques identifiés grâce à la segmentation des réseaux, l'isolation des serveurs critiques, la sécurisation des sauvegardes, le filtrage des flux, le VPN, le MFA et la centralisation des journaux.

Ainsi, ce projet constitue une **feuille de route pour renforcer progressivement la sécurité du système d'information de BioMarket** et préparer l'entreprise à la mise en œuvre effective de son SMSI et à une future certification **ISO/IEC 27001**. La démarche devra être poursuivie par la mise en œuvre des actions, leur suivi au moyen d'indicateurs, les audits internes et l'amélioration continue du SMSI.

Liste des annexes

- **Annexe A - BioMarket – Etude du contexte**
- **Annexe B– Plan Projet pour la Certification du SMSI de BioMarket**
- **Annexe C – PSSI (Politique de Sécurité des Systèmes d'Information)**
- **Annexe C1 – Matrice RACI de la sécurité**
- **Annexe C2 – Procédure de gestion des incidents**
- **Annexe C3 – Procédure de gestion des changements**
- **Annexe C4 – Procédure de gestion des habilitations**
- **Annexe C5 – Classification des actifs informationnels**
- **Annexe C6 – Programme annuel de sensibilisation**
- **Annexe C7 – Charte informatique**
- **Annexe C8 – Lettre d'engagement de la Direction**
- **Annexe D – Analyse de risques**
- **Annexe E – Plan de Continuité d'Activité (PCA)**
- **Annexe F – Plan d'Actions de Sécurité**